Risk Register - Apex Financial Partners (Fictional Firm)

ID	Asset	Threat	Why this firm is exposed	Likelihood (1-5)	Impact (1-5)	Risk Score	Rating	NIST CSF 2.0 Function	Treatment	Recommended control (CIS Controls v8 where it applies)
R-01	CRM, cloud accounting, and billing software	Unauthorized access to client records and payment details	Shared logins and accounts of former staff aren't removed	3	4	12	High	Protect	Mitigate	CIS 5 Account Management: remove accounts at offboarding
R-02	Client personal and financial data	Data breach and/or identity theft	Stored in several places with no clear access limits	3	5	15	High	Protect	Mitigate	CIS 3 Data Protection: encrypt data, limit access
R-03	Client portal	Account takeover using stolen passwords & credentials	Clients log in with no MFA (Multi-factor Authentication)	4	4	16	High	Protect	Mitigate	CIS 6 Access Control Management: require MFA
R-04	Email	Phishing & corporate email compromise	Emails containing sensitive information. No phishing training	5	4	20	Critical	Protect	Mitigate	CIS 9 Email and Web Browser Protections; CIS 14 Security Awareness and Skills Training: phishing training; CIS 6 Access Control Management: MFA on email
R-05	Payroll and HR systems	Stolen SSNs, payroll fraud, direct deposit details	Changes to bank details aren't verified by a second person	3	4	12	High	Protect	Mitigate	Process control (outside CIS v8): second-person approval for bank detail changes
R-06	Advisor laptops and phones	Theft or loss with client data on the device	Disks lacking full encryption. Frequent travel or remote work.	3	4	12	High	Protect	Mitigate	CIS 3 Data Protection: full-disk encryption
R-07	USB and external drives	Data copied, stolen, or malware installed	No policy controls on external media	3	3	9	Medium	Protect	Mitigate	CIS 10 Malware Defenses: block removable media
R-08	Shared drive and backups	Ransomware encrypts files and backups	Backups are never tested or restored	4	5	20	Critical	Recover	Mitigate	CIS 11 Data Recovery: offline backups, test restores
R-09	VPN gateway	Attackers exploit weak or vulnerable VPN, stolen credentials	Remote access depends on a device that's rarely updated	3	4	12	High	Protect	Mitigate	CIS 7 Continuous Vulnerability Management: patch on a schedule
R-10	Domain name and DNS	Domain hijacking or email spoofing	Lack of MFA, no email authentication records	2	4	8	Medium	Protect	Mitigate	CIS 9 Email and Web Browser Protections: SPF/DKIM/DMARC; CIS 6 Access Control Management: registrar MFA
R-11	API keys and integration credentials	A leaked key lets an attacker steal data or money	Keys are never rotated	3	4	12	High	Protect	Mitigate	CIS 5 Account Management: vault and rotate keys
R-12	MFA tokens and authentication apps	SIM swap, stolen phone, phished codes	SMS codes are used and there's no backup process	3	3	9	Medium	Protect	Mitigate	CIS 6 Access Control Management: app-based MFA, backup codes
R-13	Keycard system and office cameras	Unauthorized physical entry	Fobs aren't deactivated when staff leave, footage is overwritten quickly.	2	3	6	Medium	Protect	Mitigate	Physical control (outside CIS v8): deactivate fobs at offboarding
R-14	Corporate credit cards and banking credentials	Fraud and unauthorized transfers	Credentials saved in browsers or shared in email	3	5	15	High	Protect	Mitigate	Process control (outside CIS v8): dual approval for payments; CIS 6 Access Control Management: MFA on banking, no saved logins
R-15	Paper records and shredding bins	Sensitive information on thrown out or unshredded paper	Bins sit in a hallway and cleaners have after-hours access	2	3	6	Medium	Protect	Mitigate	CIS 3 Data Protection: locked bins, scheduled shredding

Scoring Key

Likelihood (1-5)

Score	Level	Meaning
1	Rare	Unlikely to happen in the next year
2	Unlikely	Could happen, but not expected
3	Possible	Might happen about once a year
4	Likely	Expected to happen more than once a year
5	Almost certain	Happening now or very frequently

Impact (1-5)

Score	Level	Meaning
1	Minimal	Minor inconvenience, no real loss
2	Minor	Short disruption, small cost
3	Moderate	Noticeable disruption or cost; some clients affected
4	Major	Serious disruption, large cost, or regulatory attention
5	Severe	Business-threatening: major data breach, long outage, lost clients

Rating bands (Risk Score = Likelihood x Impact)

Rating	Risk score range	Risks in register
Low	1-4	0
Medium	5-9	5
High	10-16	8
Critical	17-25	2

Notes

Band cutoffs (4 / 9 / 16 / 25) are a common 5x5 convention chosen as a starting point, not a standard.

Controls are cited from CIS Controls v8 where they apply. Business-process and physical safeguards (R-05, R-13, R-14) fall outside CIS v8, which focuses on technical controls, and are labeled as such.

Fictional firm. All scores are my own judgments for a hypothetical organization. No systems were tested or scanned.